

Lab: Exploiting an API endpoint using documentation_WriteUp

Link:

<https://portswigger.net/web-security/api-testing/lab-exploiting-api-endpoint-using-documentation>

Core Objectives of this Lab:

- To do API Reconnaissance and find the hidden API endpoints that are not linked by front end.
- Use the exposed API documentation to do the exploitation
- To show that if proper authentication and authorization is not done then how the exposed endpoints can be used?

Steps To Reproduce:

1. Set up the burp suite proxy in the browser.
2. Access the lab and login using the credentials provided wiener:peter

Web Security Academy Exploiting an API endpoint using documentation LAB Not solved

Back to lab description >>

Home | My account

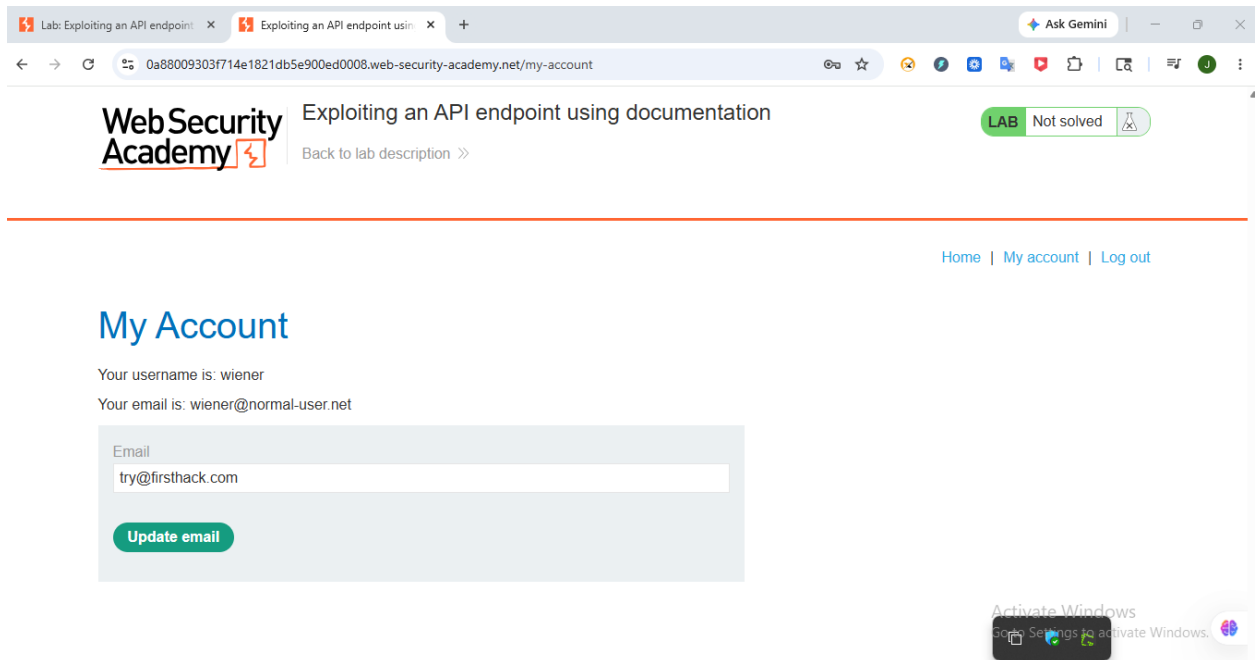
Login

Username
wiener

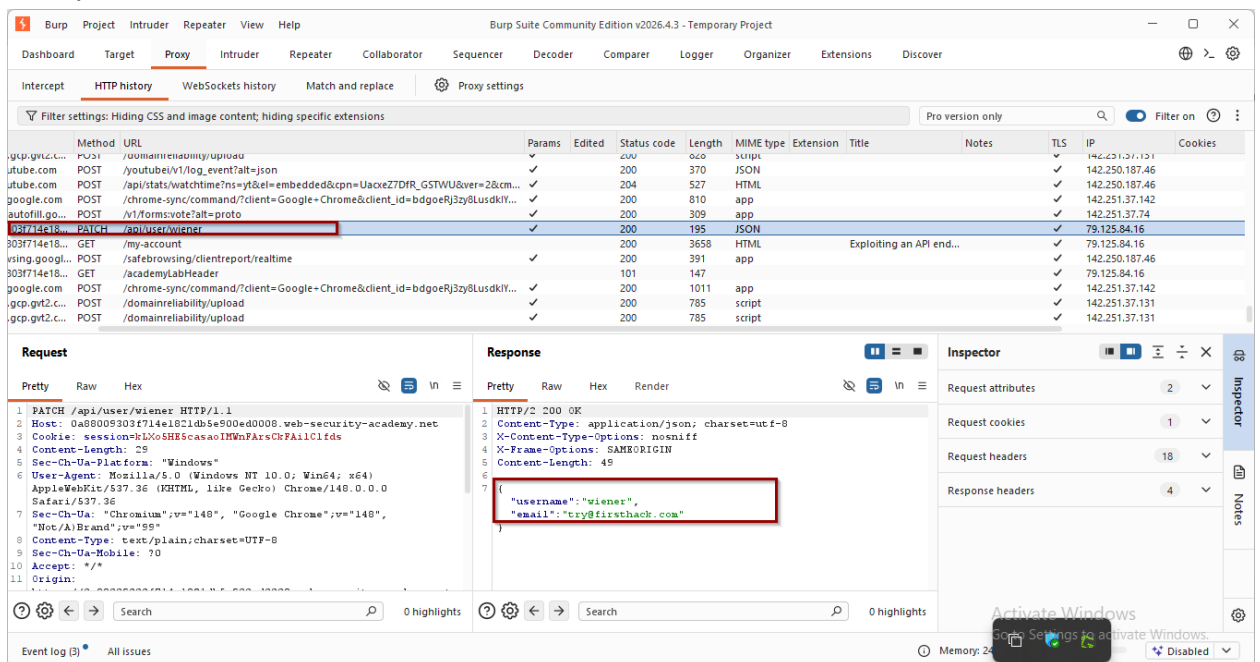
Password

Log in

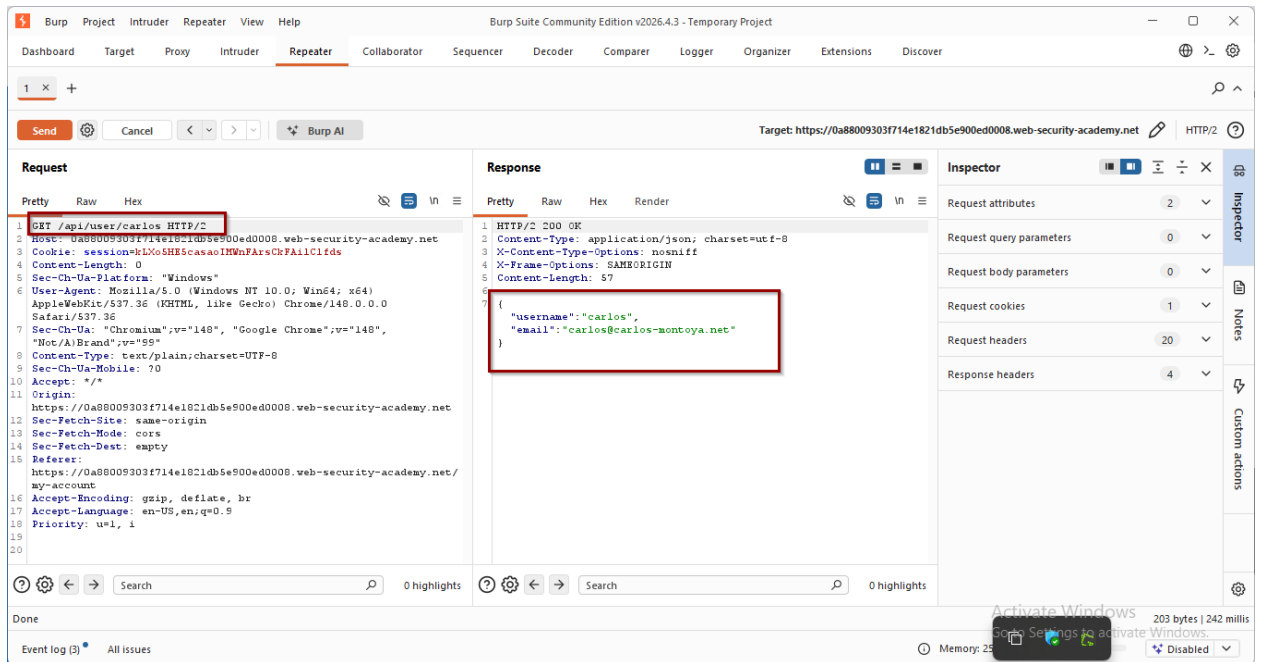
3. After that Change email address page appears and update the email address.



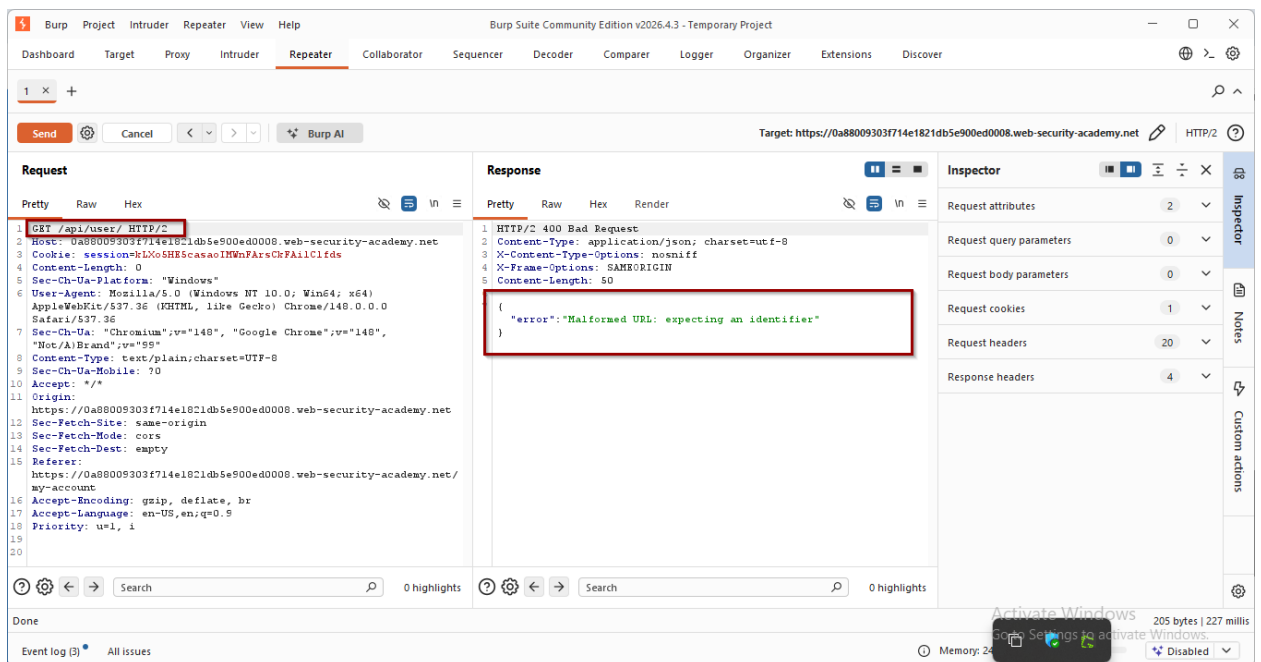
4. Goto the http history and spot the url with API in it and is most probably gonna be the api/user/wiener.



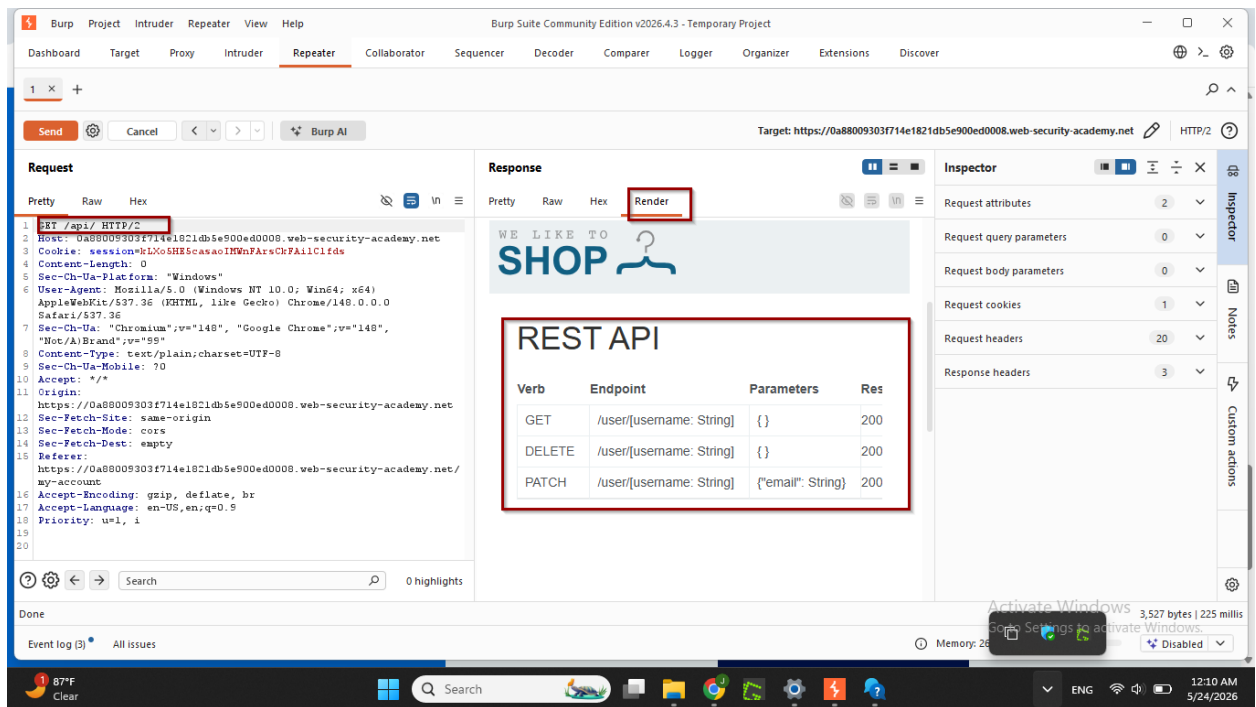
5. Select the request and send it to repeater .Now remove the PATCH request and change it to GET with the changing the wiener to carlos and removing the email info at the end .



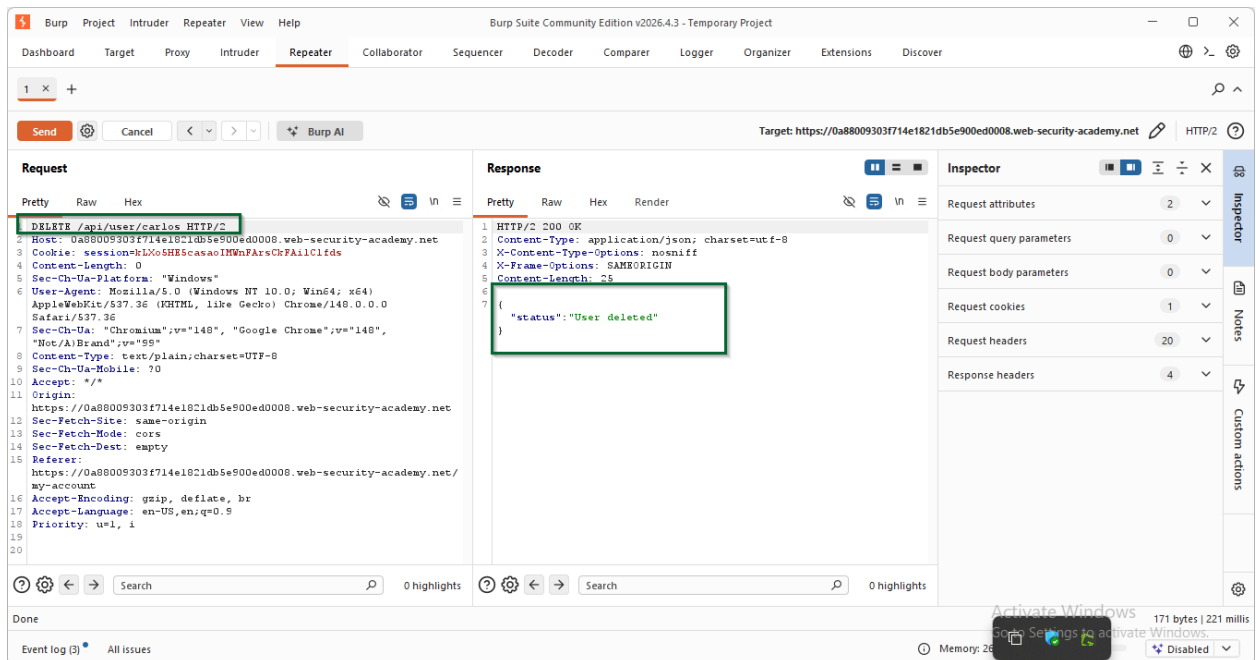
6. Now remove the carlos as well and get the info you will see that user is required no matter what.



7. Then remove the user from the api request and send it you will finally get the API hidden documentation which explains that which methods are supported with parameters.



8. Now the change the user with carlos and change Get to DELETE and send the request. You will see user is deleted and lab is solved.



Congratulations, you solved the lab!

Share your skills!

[Continue learning >>](#)[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your email is: try@firsthack.com

Email

[Update email](#)

Activate Windows

Go to Settings to activate Windows.



Remediations to prevent Exploitation:

- **Authentication Mechanism:** First authenticate who can see the documentation(valid admin or developer).
- **Authorization Mechanism:** Make sure the backend system should check every request against the authorized tasks.
- **Filter Endpoint Exposure:** Ensure documentation generators only include officially supported, public-facing endpoints.